NIST RMF Practical Project

Hospital Electronic Health Records (EHR) Risk Assessment

Project type: Self-directed simulated GRC portfolio project

Purpose

This project applies practical risk-management concepts to a fictional hospital EHR environment. It demonstrates how a GRC analyst can identify risks, recommend treatment, track remediation, evaluate evidence, and determine whether findings are ready for closure.

Scope

Five hypothetical risk areas were explored: an unpatched EHR vulnerability; backup and recovery weaknesses; former employees' accounts; weaknesses in the employee offboarding process; and missed quarterly user access reviews. Scenarios included temporary safeguards, overdue remediation, formal risk acceptance, control testing, exceptions, and evidence-based closure.

Risk register overview

ID	Risk area	Key GRC focus	Scenario status
EHR-001	Unpatched vulnerability	Mitigation, interim safeguards, patch verification	Remediation in progress in scenario
EHR-002	Backup and recovery	Data integrity, RTO/RPO, recovery evidence	Closure review pending in scenario
EHR-003	Former employee accounts	Access removal and verification	Remediated in scenario
EHR-004	Offboarding process	Ownership, escalation, monitoring, retesting	Ready for closure review in scenario
EHR-005	Quarterly access reviews	Control operation, exceptions, overrides	Investigation required in scenario

Key learning outcomes

• A risk rating supports prioritization but should be considered alongside urgency, exposure, business impact, and evidence.

• Risk owners and remediation owners have different accountabilities.

• Interim safeguards may reduce exposure without eliminating the underlying vulnerability.

• Risk acceptance requires documented rationale and appropriate authority; it does not close the technical deficiency by itself.

• Controls must be assessed for design, implementation, and operating effectiveness.

• A successful backup job does not prove recoverability; restoration, integrity, RTO, and RPO should be tested.

• Findings should be closed only after evidence, residual-risk assessment, and required approvals are complete.

Methodology and limitations

All organizations, findings, ratings, recovery targets, and test results in this project are fictional and illustrative. No actual hospital system or evidence was accessed. The project applies selected practical concepts related to the NIST RMF but is not a complete formal RMF implementation, system categorization, control assessment, authorization package, or authorization-to-operate decision. A real engagement would require approved organizational methods, real evidence, applicable requirements, and authorized stakeholders.

Repository contents

README.md; NIST-RMF-Hospital-EHR-Risk-Register.xlsx; Methodology-and-Limitations.md; and this executive summary.